

Change Control and Configuration Management

A practical blueprint for Mesusa Corporation

MODULE 9 ROUGH DRAFT

Prepared for Moira Bennie, Chief Information Officer

Prepared by George Everett, Senior Developer

RECOMMENDATION

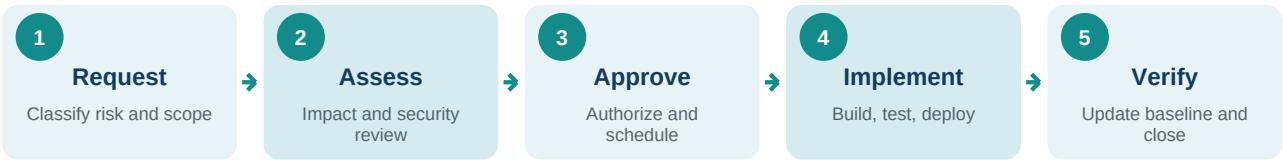
Start with one integrated process

MeCo should launch a lightweight process that combines change control with security-focused configuration management. A small Change Advisory Board (CAB), risk-based approvals, and evidence captured in existing engineering tools will provide control without slowing ordinary delivery.

Change control Governs the decision to alter a system, service, environment, or document. It requires a reason, impact analysis, approval, implementation plan, validation, and closure.	Configuration management Defines configuration items, establishes approved baselines, records relationships and versions, and checks that the actual environment matches the approved state.
--	--

How the two disciplines fit together

Configuration management supplies the inventory, baselines, and status information. Change control is the decision gate that protects those baselines. Each request should name affected configuration items, record the security impact, and update the baseline after deployment and verification.



Configuration management records the baseline, CI status, and evidence at every step.

Figure 1. The integrated request and baseline lifecycle.

Why this matters

NIST describes security-focused configuration management as a way to manage and monitor system configurations, maintain security, and reduce organizational risk. NIST also recommends integrating secure software development practices into each organization’s lifecycle (Johnson et al., 2011; Souppaya et al., 2022).

BENEFITS AND TRADEOFFS

Use control without creating a bottleneck

What MeCo gains	Risk to manage	Practical response
Traceability A production state connects to a request, owner, approval, and deployment evidence.	Extra documentation can feel burdensome.	Use one request record and automatic links to source control and CI/CD logs.
Safer releases Impact analysis, testing, and rollback planning reduce avoidable outages and security regressions.	Reviews can slow urgent work.	Use preapproved standard changes and a documented emergency path.
Faster recovery Versioned baselines and release records make rollback and incident response more reliable.	Stale records can create false confidence.	Automate status capture and audit selected services each quarter.
Clearer ownership Development, operations, security, and business owners share one decision record.	Approvals can become a bottleneck.	Publish authority limits, backups, and a five-day target for normal decisions.

Recommended operating model

MeCo does not need a new department at launch. Assign a part-time change coordinator and form a standing CAB chaired by an engineering or IT service manager. The core group should include the senior developer, operations or platform lead, security representative, and the affected product owner. Invite specialists only when a request touches their area.

Role	What the role does
Executive sponsor	Sets risk appetite, approves policy and high-risk exceptions, and reviews measures.
Change coordinator	Checks intake quality, routes requests, maintains the CAB agenda, and reports results.
Technical owner	Completes analysis, testing, rollback planning, implementation, and evidence capture.
Security representative	Reviews changes that alter exposure, controls, identities, data flows, or exceptions.
CAB	Approves normal and high-risk requests within delegated limits and resolves conflicts.

Build the process into daily work

The process should appear throughout the secure development lifecycle, not only before a production release. The activities below use the familiar initiation-to-disposition lifecycle and align with NIST secure-development guidance.

Phase	Change control activity	CM evidence
Initiation and planning	Classify new-service and major-scope requests; identify security, privacy, availability, and ownership needs.	Create service record, CI list, naming standard, initial baseline, and ownership record.
Requirements and design	Review requirement changes, architecture decisions, threat-model findings, and vendor selections.	Version requirements, diagrams, data flows, threat model, and security-control design.
Build and integration	Approve code, dependency, pipeline, infrastructure, and secrets-management changes through peer review and scans.	Maintain source revisions, build definitions, dependency versions, artifacts, and infrastructure-as-code state.
Verification and release	Authorize promotion after functional, security, and rollback evidence is complete.	Record test results, approval, deployment manifest, release candidate, and production baseline.
Operations and maintenance	Process patches, vulnerability fixes, access changes, drift findings, capacity work, and incident repairs.	Monitor drift and retain runbooks, access lists, logs, asset relationships, and audit results.
Retirement and disposition	Approve decommissioning, data disposition, dependency removal, and access revocation.	Archive final baseline and evidence; update inventory and record revoked credentials.

Design principle

A request should be as detailed as the risk requires. Routine, repeatable changes can use a preapproved template. A normal change needs review before implementation. High-risk work needs CAB, security, and business approval. Emergency changes can proceed to restore service or contain an active threat, but they require an accountable approver and a post-implementation review within two business days.

REQUEST VOLUME AND IMPLEMENTATION

Plan for the requests MeCo will actually see

MeCo has not supplied historical request volume. These figures are planning estimates for one medium-sized product or service team for a year. They should be recalibrated after a 90-day pilot. Routine commits bundled into a planned release are not counted separately unless they carry separate risk or approval needs.

SDLC phase	Estimated requests per year	Typical work
Initiation and planning	8–12	New initiatives, scope changes, onboarding, policy and risk decisions.
Requirements and design	15–25	Architecture decisions, data flows, vendors, and threat-model remediation.
Build and integration	50–80	Code, dependencies, pipelines, infrastructure, and configuration work.
Verification and release	24–36	Planned releases, promotions, rollback decisions, and security fixes.
Operations and maintenance	70–110	Patches, access, configuration, vulnerability, capacity, and emergency repairs.
Retirement and disposition	3–6	Component retirement, credential revocation, data disposition, and archival.
Total	170–269	Operations and maintenance will create the largest share.

A 90-day launch plan

Days 1–30 Name the sponsor and coordinator. Define CIs and owners. Publish policy, categories, request form, and weekly CAB schedule.	Days 31–60 Pilot with one team. Link source control and CI/CD evidence. Create baseline templates. Review every emergency change.	Days 61–90 Expand to other teams. Automate evidence capture and drift reporting. Publish measures and refine approval thresholds.
---	---	---

Make the process easy to follow

The coordinator should reject incomplete requests at intake rather than using CAB time to repair them. Requesters need brief training on when a ticket is required and how to describe impact. Technical owners need to attach testing, rollback, deployment, and validation evidence. Approvers need a simple risk rubric and clear authority limits.

Every request should show	Why it matters
Request ID, owner, service, and affected configuration items	Connects responsibility and scope to the inventory and baseline.
Reason, category, impact, and security assessment	Lets approvers make a decision that matches business and technical risk.
Test result, implementation steps, and rollback plan	Shows that the change can be deployed and reversed safely.
Approvals, time window, deployment evidence, and closure result	Provides traceability from decision to production outcome.

Measures Moira should review monthly

Track the percentage of production changes with complete approval and evidence; emergency-change rate; change success and rollback rates; unauthorized or drift findings; time to approve normal changes; vulnerability remediation age; and post-implementation review completion. The goal is controlled, visible change and lower avoidable risk—not zero change.

Conclusion

MeCo should start now with an integrated, security-focused process, a part-time coordinator, and a small CAB. Existing ticketing, source control, and CI/CD tooling can supply most of the evidence needed for launch. After the pilot, actual request volume and quality measures should determine whether MeCo needs a full-time change manager or additional configuration analysts.

Decision
Approve a 90-day pilot with one product team and a weekly CAB.

SOURCES

References

- Johnson, A., Dempsey, K., Ross, R., Gupta, S., & Bailey, D. (2011). *Guide for security-focused configuration management of information systems* (NIST Special Publication 800-128). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-128>
- Kissel, R., Stine, K., Scholl, M., Rossman, H., Fahlstrom, J., & Gulick, J. (2008). *Security considerations in the system development life cycle* (NIST Special Publication 800-64 Revision 2). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-64r2>
- National Institute of Standards and Technology. (2013). *Security and privacy controls for federal information systems and organizations* (NIST Special Publication 800-53 Revision 4), CM-3 through CM-5. <https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-53.pdf>
- Souppaya, M., Scarfone, K., & Dodson, D. (2022). *Secure software development framework (SSDF) version 1.1: Recommendations for mitigating the risk of software vulnerabilities* (NIST Special Publication 800-218). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-218>

AI assistance disclosure. OpenAI Codex was used to help locate sources, organize and revise the report, and create the visual layout and graphics. The author reviewed and approved the final content.